

Risk Response Planning

Module 5

Objectives

- Risk response strategies- how to respond to negative and positive risks
- Risk control to limit exposure to risk
- How to mitigate negative and opportunity risk
- Monitoring risk throughout risk management life cycle
- Apply the COSO framework to risk mitigation and monitoring

Risk Response Planning

- To take a proactive posture
- To understand what resources will be needed for risk management.

Criticality Risk Type	Should the risk be mitigated?
High/Critical Risks	Mitigate Negative Risk - accept, transfer, mitigate through action and avoid Positive/Opportunity Risk - accept, share, enhance, and exploit
Medium Risks	Potentially mitigation - usually accept - which means do nothing until the risk moves to high or critical.
Low Risks	Accept - which means do nothing until the risk moves to high or critical.

Positive Risk Response Strategies

- Escalate: transfer
- Enhance: try to seize the opportunity
- Exploit: optimum strategy
- Accept: least desired strategy
- Share: when solo realization of opportunity is hard



Negative risk response strategies

- Escalate: pass it on to the higher ups
- **Mitigate**: actionable plan to lessen the risk and implement with control
- Transfer- to insurance company or third party.
- Avoid: Making necessary changes to avoid risk
- **Accept**: determination that it is too costly to mitigate the risk

Cyber Risk Mitigation

ACCEPT

Accepting Risk: Perfect security is impossible; therefore, your organization should be prepared to strategically accept some risk as a necessary—though potentially unpleasant—part of doing business. You can accept the risk if the risk is inevitable, too expensive to manage, or if the risk provides you an opportunity to obtain some sort of desirable return.

AVOID

Avoiding Risk: You may decide to avoid the risk altogether through elimination of certain activities or situations. For example, electing to not collect certain types of data is a powerful method of avoiding risk. Your company should decide to collect sensitive data only if it can be protected.



MITIGATE

Mitigating Risk: You can limit the risk in part or in full through the implementation of risk reducing actions, policies, or processes. You can also mitigate some risks through third-party services and solutions. Make sure that your executives, such as a CIO/CISO, are scrutinizing risk and seeking mitigation strategies as appropriate.

TRANSFER

Transferring Risk: One way to manage cyber risk involves the transference of that risk. Transferring cyber risk is most often done through the purchase of cyber insurance and through third-party solutions, which accept the risk as a part of their business services.

Cyber Risk Mitigation

Risks

- Data Breach
- Phishing Attacks

Mitigation Strategies

- Data Encryption
- Data access control
- Data backup practices
- Employee training
- Network Security plans
- Incident recovery and response plan

Steps for making decisions about risk mitigation

1. Identify a risk owner
2. Risk register
3. Look at the quantitative and qualitative analysis
4. Identify subject matter experts to support the mitigation strategies
5. Work with the risk management department to test that the mitigations will work.



Risk Monitoring- Root cause analysis

Steps to identify the root cause as part of monitoring risk:

1. Define the event
2. Finding the root cause
3. Find solutions
4. Take action
5. Verify solution effectiveness



Risk Monitoring

- Periodic or ongoing evaluations for the functioning of:
 - Controls that support the risk
 - The current risk management process
- Reviewing the key risk indicators which drive a proactive risk management
 - Helps to identify when risks are becoming an issue

For the Data Analyst

- **Risk appetite:** understand the position of the organization when it comes to mitigating a risk as some organizations will simply accept risk while other organizations will implement measures to lessen the risk
- **Risk Culture:** Understanding the risk culture and the organization's stance on risk mitigation is important when you are identifying risk within your data analysis.



In_Class Activity- Risk Response Planning

Using the risk heat map, quantitative and qualitative risk assessment from your prior activity as a guid, develop the risk responses

Considerations:

Brainstorm and develop risk response plans for the top-priority critical risks.

Consider applicable response strategy (risk avoidance, mitigation/reduction, transfer, acceptance) and justify your choice for the risk(s) under consideration.

Note: critical thinking and creativity is required for this activity